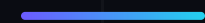




FINAL PRESENTATION · CPSC 69100 MASTER'S PROJECT

Build or Buy? A Hybrid, Zero-Trust CIAM Platform

Customer identity & access management on
Angular 21 and Spring Boot 4 — secure access,
by design.



PRESENTERS

Robert C. Oliver, Jr. · Travis L. Lester

ADVISOR

Dr. Al-Sharif · Lewis University

DATE

2026

THE PROBLEM

Identity is the new perimeter — and the hardest thing to get right.

- 🛡️ Stolen credentials are among the **most common and slowest-to-contain** breaches; the average breach now costs **\$4.88M**.
- 💰 Commercial CIAM is priced **per monthly active user** — a tax on the very growth a startup is chasing.
- 🔒 A fully in-house build adds credential friction and loses **single sign-on**. Neither pole is ideal.

Should an organization **build** or **buy** its identity system? TesseraApp is a working answer: a hybrid that does both.

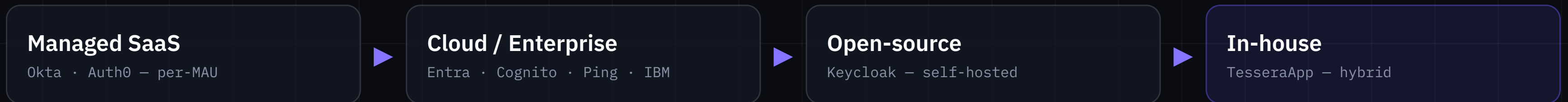
OBJECTIVES

What we set out to build

- 1 A production-style **authentication core**: JWT, refresh-session rotation, MFA, federation.
- 2 **Permission-based role access control** with organization scoping.
- 3 A complete **administrative console** and **user self-service** experience.
- 4 A real **business domain** — customers & invoices — to secure.
- 5 **Auditability** of every security-relevant action.

LITERATURE · THE BUILD-VS-BUY SPECTRUM

Where TesseraApp sits



 Keycloak proves a real market for **self-hosted CIAM** — control and data ownership, no per-MAU bill.

 The gap: sovereign, predictable, production-grade identity **at small scale** — schools, startups, small business, non-profits.

BACKGROUND

Why CIAM, and why hybrid tokens

- 👤 **CIAM** vs. traditional IAM: external, self-registering users at internet scale.
- 🛡️ **Zero-trust:** never trust, always verify — every request re-validated, access revocable mid-session.
- 🔄 **Stateless JWT** scales but can't revoke; **stateful sessions** revoke but don't scale — TesseraApp uses a **hybrid** of both.

REQUIREMENTS · SRS HIGHLIGHTS (IEEE 830)

Scope in one glance

Access

Registration, email verification, login, logout, password reset.

MFA & SSO

Authenticator app (TOTP) + SMS; federated login via OAuth2 / OIDC.

RBAC

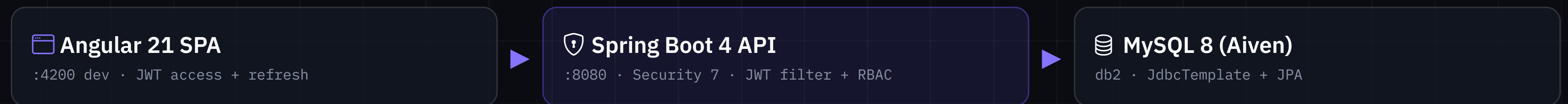
Seven-role permission control; organization-scoped administration.

Audit & sessions

Full audit logging; per-device session management.

ARCHITECTURE · THREE TIERS, ONE CONTRACT

A layered, stateless system



Described through four architectural views plus scenarios:

- Logical
- Process
- Development
- Physical
- + Scenarios

ANATOMY OF A REQUEST

Seven gates, every request

1 · Network edge / CORS

2 · JWT validity

3 · Brute-force gate

4 · Authentication

5 · URL authority

6 · Method @PreAuthorize

7 · Org scope

✓ Any gate can reject outright; none trusts that the earlier ones did their job.

📄 Every request is **audited regardless of outcome** — success or failure.

SECURITY MODEL · THE DIFFERENTIATOR

Stateless to scale, stateful to revoke

Access tokens

Stateless, 30-min, HMAC-512, verified by signature — no DB hit per request.

Refresh sessions

5-day sliding, server-tracked, **rotated on every use**.

Reuse detection

Replaying an old token **revokes the whole family**.

MFA

Challenge-bound TOTP + SMS; single-use recovery codes.

RBAC

Permission strings enforced at **URL and method** level.

Audit

Every security event written to an immutable trail.

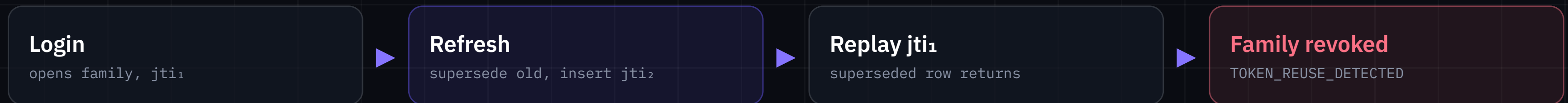
JWT · MINT, VERIFY, TRUST NOTHING TWICE

Two token types, one filter

- 🔑 **Access (30 min):** embeds the user's authorities — authorization needs no database lookup.
- 🔄 **Refresh (5 days):** deliberately carries **no authorities**, so it can never be used as an access token.
- 🕒 `CustomAuthFilter` checks signature, expiry, and that `issued-at > passwordChangedAt` — a password change instantly invalidates every token, every device.

REFRESH TOKENS · ROTATE, DETECT, REVOKE

The security centerpiece



Rotation is deliberately **not transactional**: the family revocation must **commit, then throw** — inside a transaction the throw would roll back the revocation, reversing the very containment it had just performed.

AUTHENTICATION · EVERY PATH, ONE FRONT DOOR

Every path mints the same JWT

TOTP

RFC 6238, in-house; ZXing only rasterizes the QR. Challenge-bound; recovery codes.

SMS

Twilio one-time code, live in production; TOTP takes precedence when both are enabled.

Federated

Google / GitHub / Microsoft via OAuth2 code flow; find-or-create, then our JWT.

Passkey

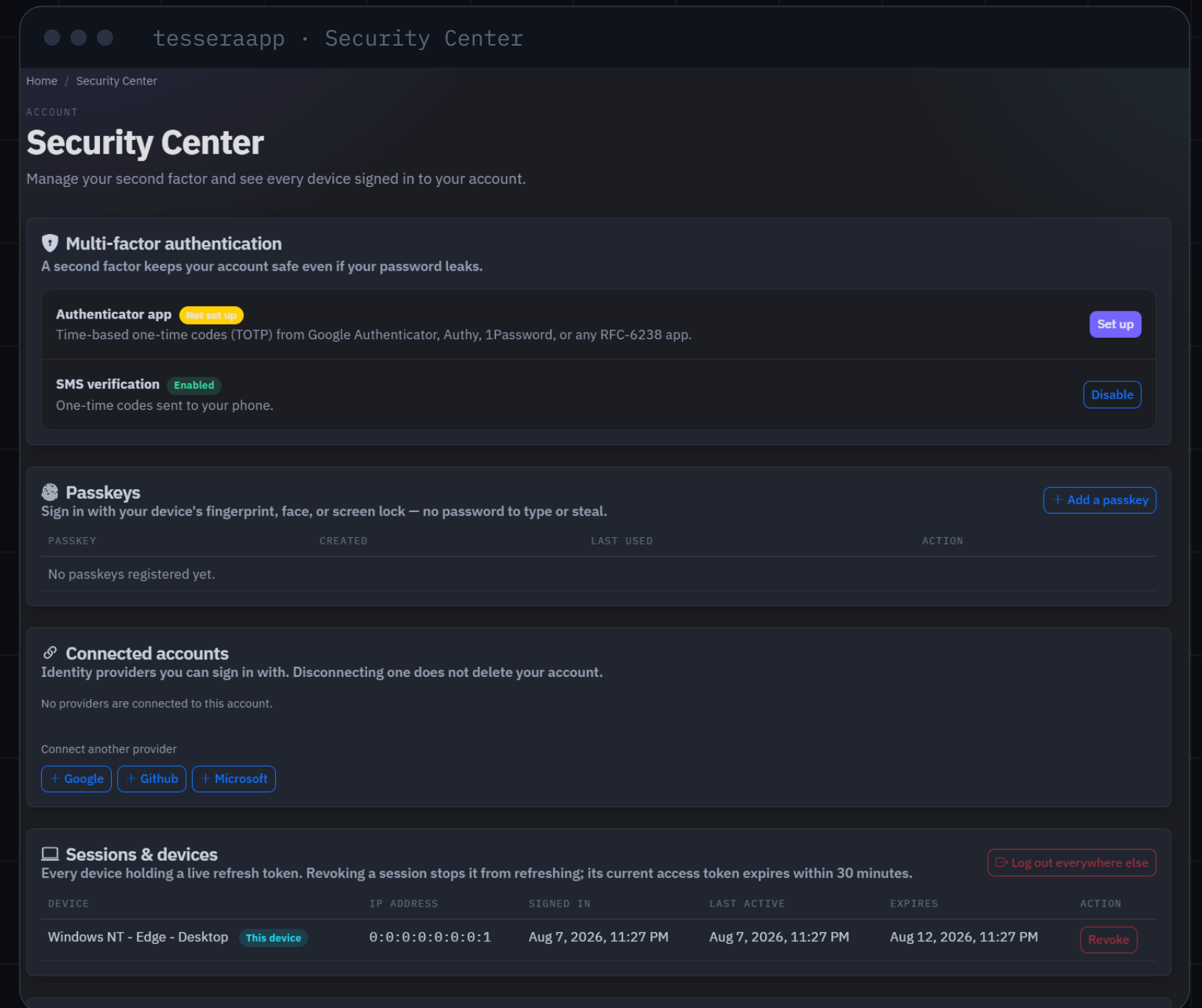
WebAuthn, usernameless; the credential picker resolves the account and skips MFA and step-up entirely.

Password, TOTP, a federated provider, or a passkey — **all converge on one token-issuance seam**, so RBAC, MFA policy, and audit apply identically.

AUTHENTICATION · PASSWORDLESS, PHISHING-RESISTANT

Passkeys: nothing to type, nothing to steal

-  Built on `webauthn4j-core`, not Spring Security's session-based WebAuthn module — the app is stateless JWT throughout.
-  **Usernameless login:** no identifier submitted; the browser's own credential picker resolves the account from the credential ID.
-  Already phishing-resistant and bound to one authenticator — a passkey login **skips risk assessment and step-up** and mints tokens directly.
-  Adoption is **nudged, not forced**: a one-time, dismissible prompt appears right after login for any account with no passkey enrolled yet.



SELF-SERVICE, FROM SECURITY CENTER

AUTHORIZATION · PERMISSION STRINGS, NOT ROLES

Seven roles, fine-grained permissions

- ☰ One role per user, carrying a comma-separated permission string like `READ:USER, UPDATE:CUSTOMER` — split into Spring authorities and embedded in the token.
- 🛡️ Enforced at **both URL and method level** (`@PreAuthorize`) so the two layers can never drift.
- 👤 A user can **never elevate their own role**; reassignment is admin-only, audited, and bounded by a **1–7 privilege-tier ladder** that blocks elevation-by-proxy. Org admins are scoped to their own organization; admins can revoke any account's sessions.

AUDIT · WITHOUT CLUTTERING THE REQUEST PATH

Everything is written down

- 🔊 Controllers publish a Spring **application event**; a separate listener writes the row — logging never sits on the hot path.
- ☁ **Operational logs**: Amazon CloudWatch in the AWS deployment (7-day retention, env-driven levels); standard console logging when running locally.
- 🛡 The same trail powers a **brute-force gate** (5 failures / 15 min → generic rejection).
- 🕶 **Anti-enumeration** across login, registration, and reset — the API never reveals whether an email exists.

TECHNOLOGY STACK

Built on current, supported tools

FRONTEND	Angular 21, Bootstrap 5, RxJS
BACKEND	Spring Boot 4, Java 21, Spring Security 7
DATA	MySQL 8 — JdbcTemplate (identity) + JPA (business)
AUTH	JWT (HMAC-512), OAuth2 client, ZXing (TOTP QR), Twilio (SMS)
OPS	Docker (multi-stage), OWASP Dependency-Check, CI/CD → AWS

IMPLEMENTATION HIGHLIGHTS

Engineering decisions that paid off

- 🔑 A single token-issuance seam (`SessionService`) → every login — password, TOTP, step-up, federated, or passkey — is one revocable session.
- 🌀 A full **threat-protection layer**: login-anomaly detection → step-up, an admin security dashboard, a two-tier rate limiter, and per-account lockout.
- 🔗 Authorization in depth: URL + method RBAC, a **capability catalog** for specific 403s, and organization-scoped admin.
- 🔄 Two persistence strategies by trust boundary, an idempotent `schema.sql`, and single-flight token refresh — no refresh storms.

LIVE DEMONSTRATION

Let's see it working.

1 · Register → verify → login → 2FA

2 · Admin & RBAC

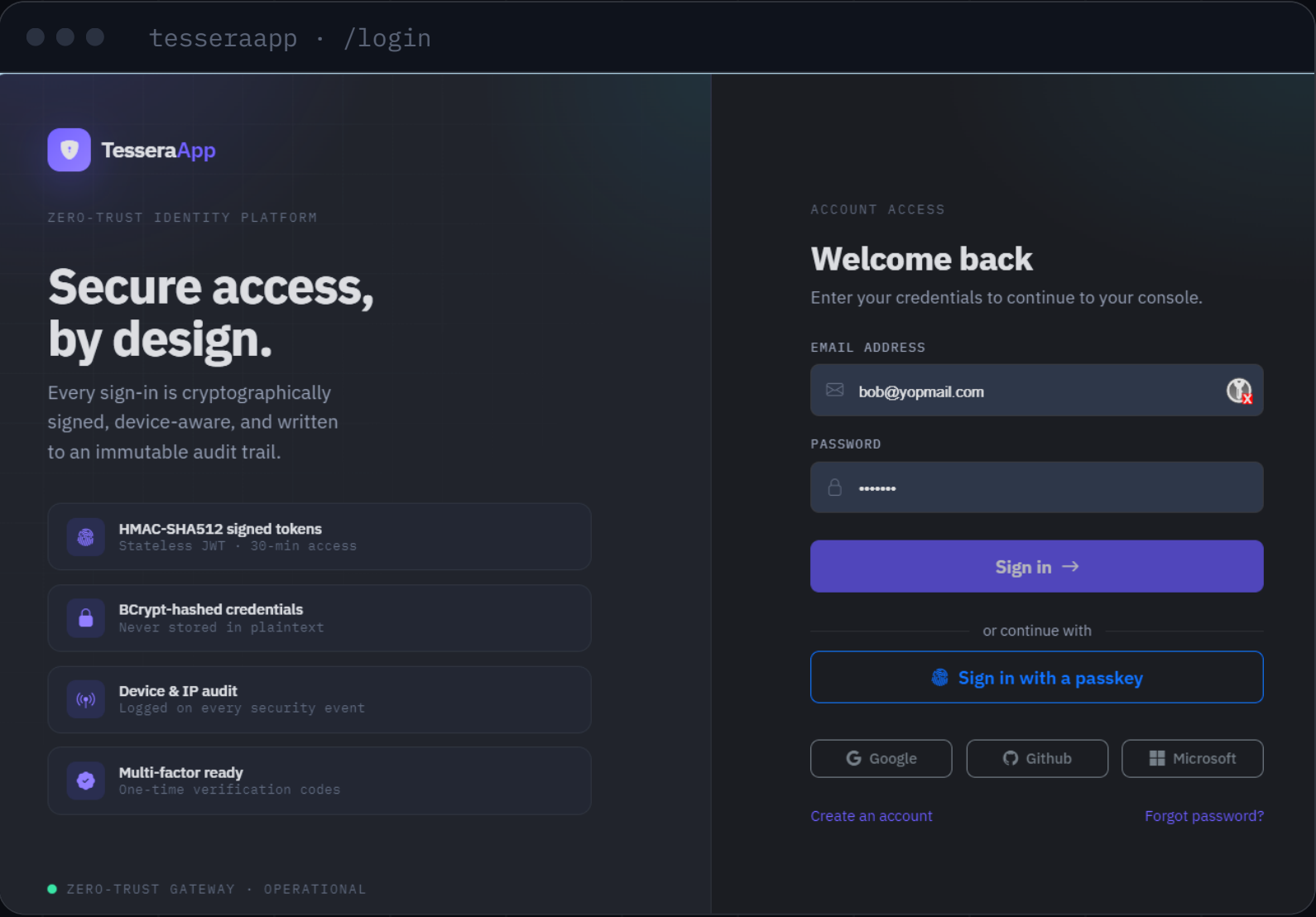
3 · Customers & invoices

4 · Federated login

| SWITCH TO THE RUNNING APP

The full authentication journey

- Register a new account → account created disabled
 - Verify via the emailed link → account activated
 - Log in → authenticator challenge → dashboard
 - Open Security Center: enroll authenticator, save recovery codes
 - View active devices → revoke a session
- 



Administration & role-based access

- Sign in as `eve.admin` (ROLE_ADMIN)
 - Open the `user directory`; open a user detail
 - Reassign their role → change appears in their `audit log`
 - Show the `roles × permissions matrix`
 - Org scoping: an org admin sees only their organization
- LIVE DEMO

tesseraapp · /users

Home / Users

ADMINISTRATION

User directory

28 account(s) in the directory

ID	PHOTO	NAME	EMAIL	ROLE	MFA	STATUS	ACTION
29		Robert Oliver	bobby_flyff@yahoo.com	ROLE_USER	OFF	ACTIVE	Manage
28		Robert Oliver Jr	bobbylon127@gmail.com	ROLE_USER	OFF	ACTIVE	Manage
27		Robert C Oliver Jr	bbobbylon@users.noreply.github.com	ROLE_USER	OFF	ACTIVE	Manage
26		Bob oliver	bob11@yopmail.com	ROLE_USER	OFF	ACTIVE	Manage
25		Frank AppAdmin	frank.app@tessera.dev	ROLE_APPLICATION_ADMIN	OFF	ACTIVE	Manage
24		Dave OrgAdmin	dave.org@tessera.dev	ROLE_ORGANIZATION_ADMIN	OFF	ACTIVE	Manage
23		Bob Mod	bob.mod@tessera.dev	ROLE_MODERATOR	OFF	ACTIVE	Manage
22		Alice Guest	alice.guest@tessera.dev	ROLE_GUEST	OFF	ACTIVE	Manage
21		Eve Admin	eve.admin@tessera.dev	ROLE_ADMIN	OFF	ACTIVE	Manage

- ## Export customers / invoices to Excel (Apache POI)

● LIVE DEMO

tesseraapp · /customers/new

 TesseraApp

Ctrl K

Customers ▾ Invoices ▾ Services ▾ Admin ▾ 

Home / Customers / New

 **New Customer**

Name

Email

Address

Phone

Type

INDIVIDUAL

Status

ACTIVE

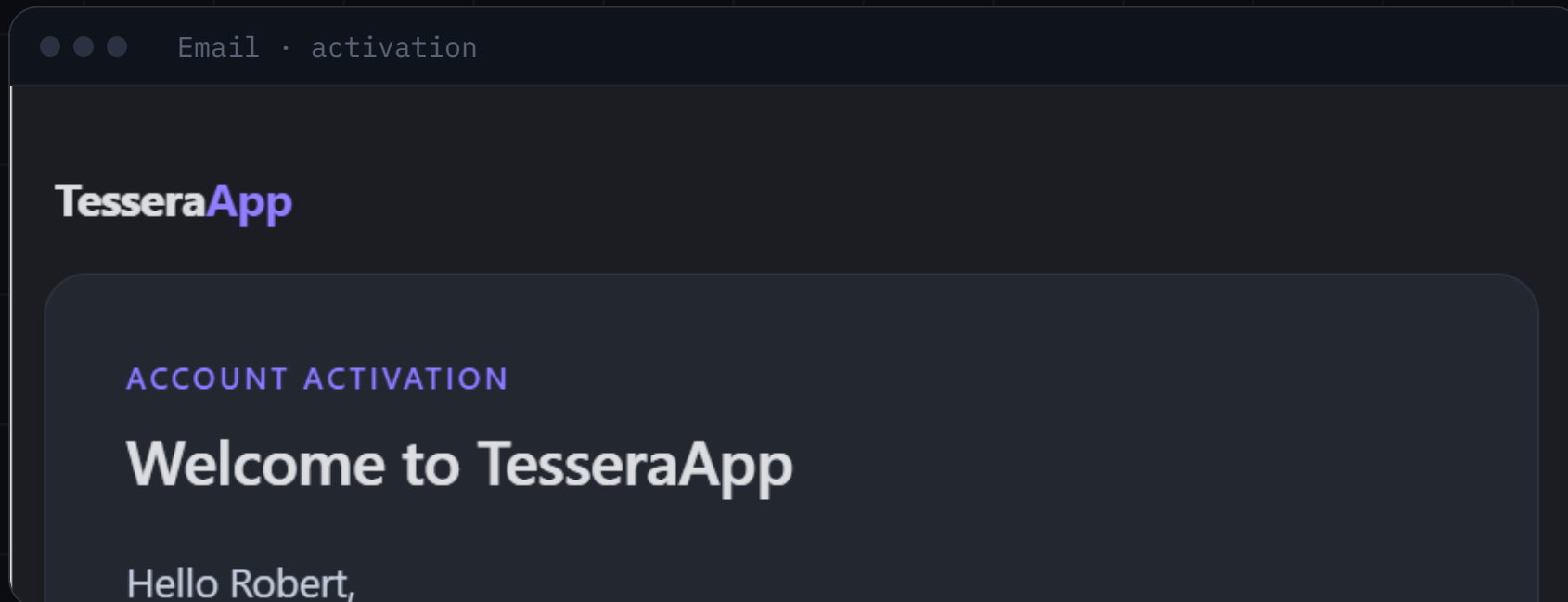
Image URL

Save Customer

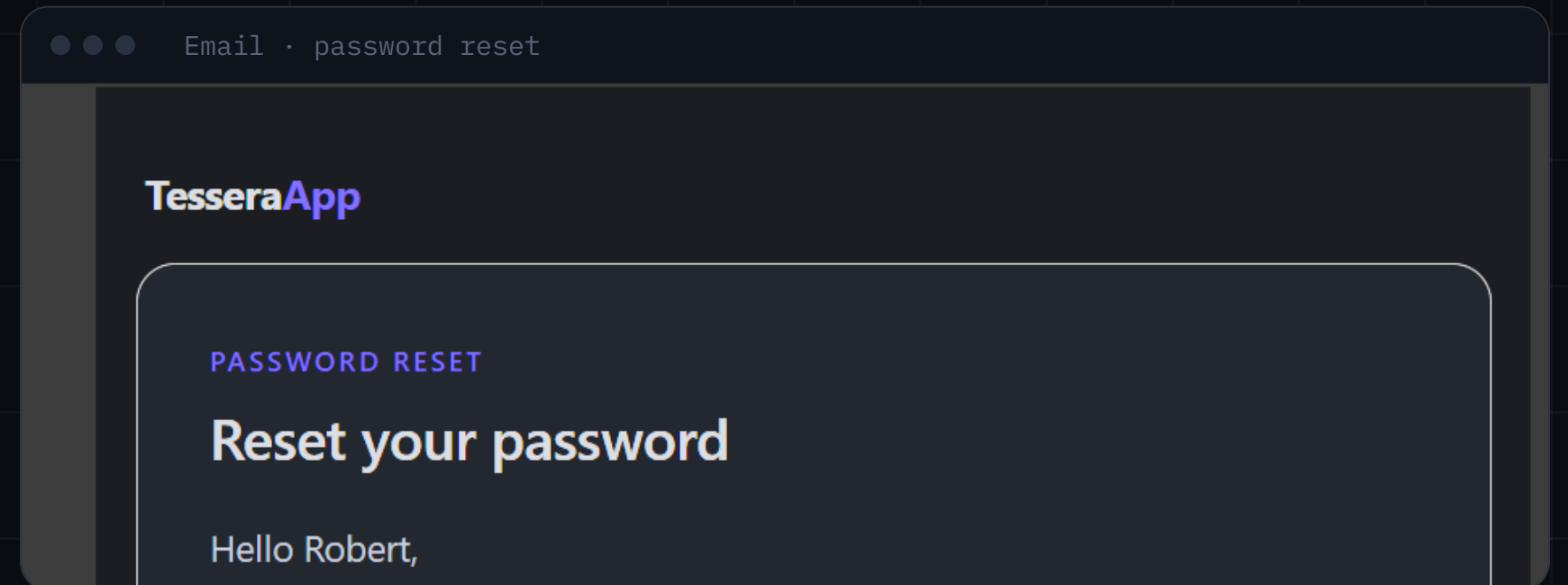
More of what shipped – I

A FEW MORE, QUICKLY

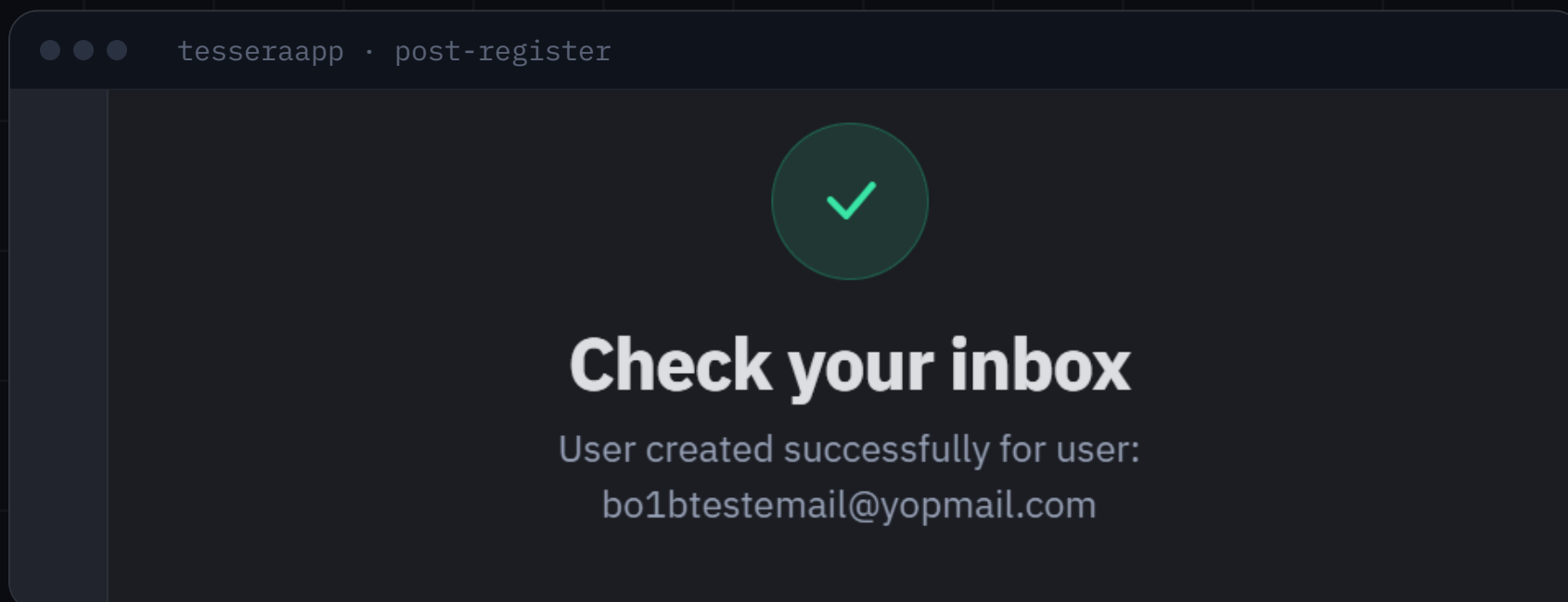
More of what shipped — II



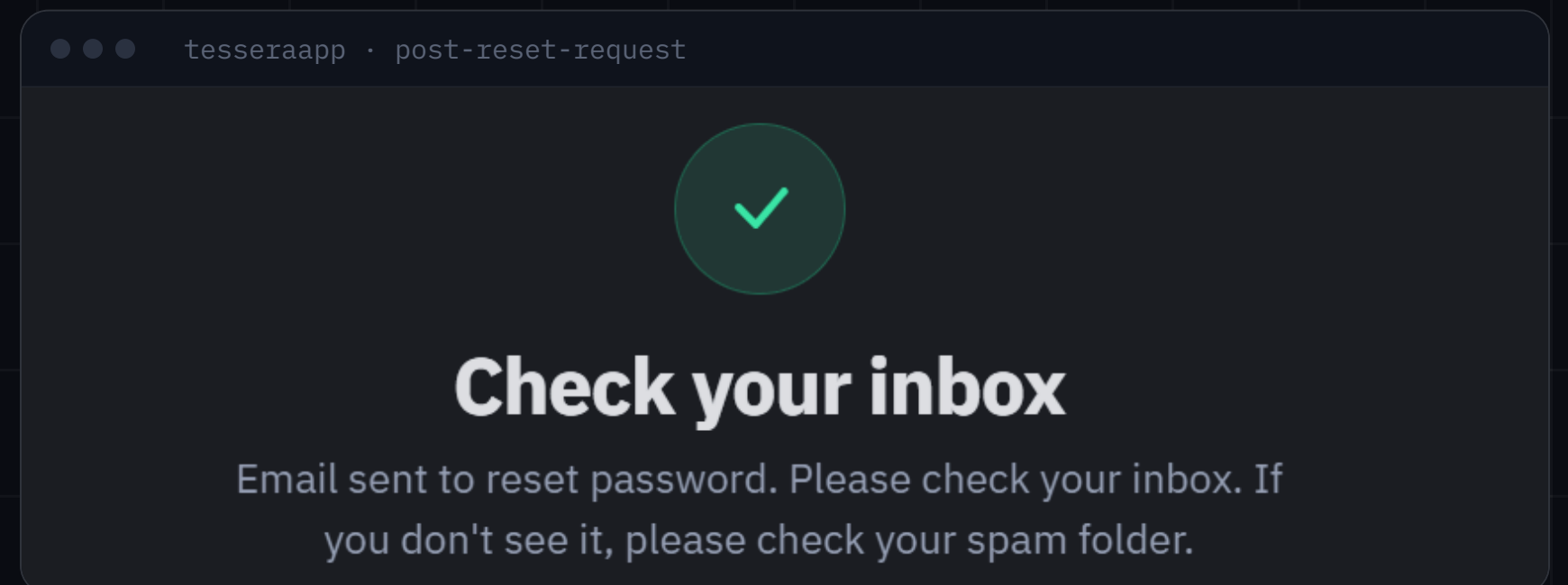
Branded transactional email — account activation, delivered via the app's mail pipeline.



Password reset email with a single-use, time-limited link.



Post-registration confirmation — account created, verification link sent.



Post-reset-request confirmation — same neutral response whether or not the email exists.

DEMO · SCENARIO 4

Federated login (OAuth2)

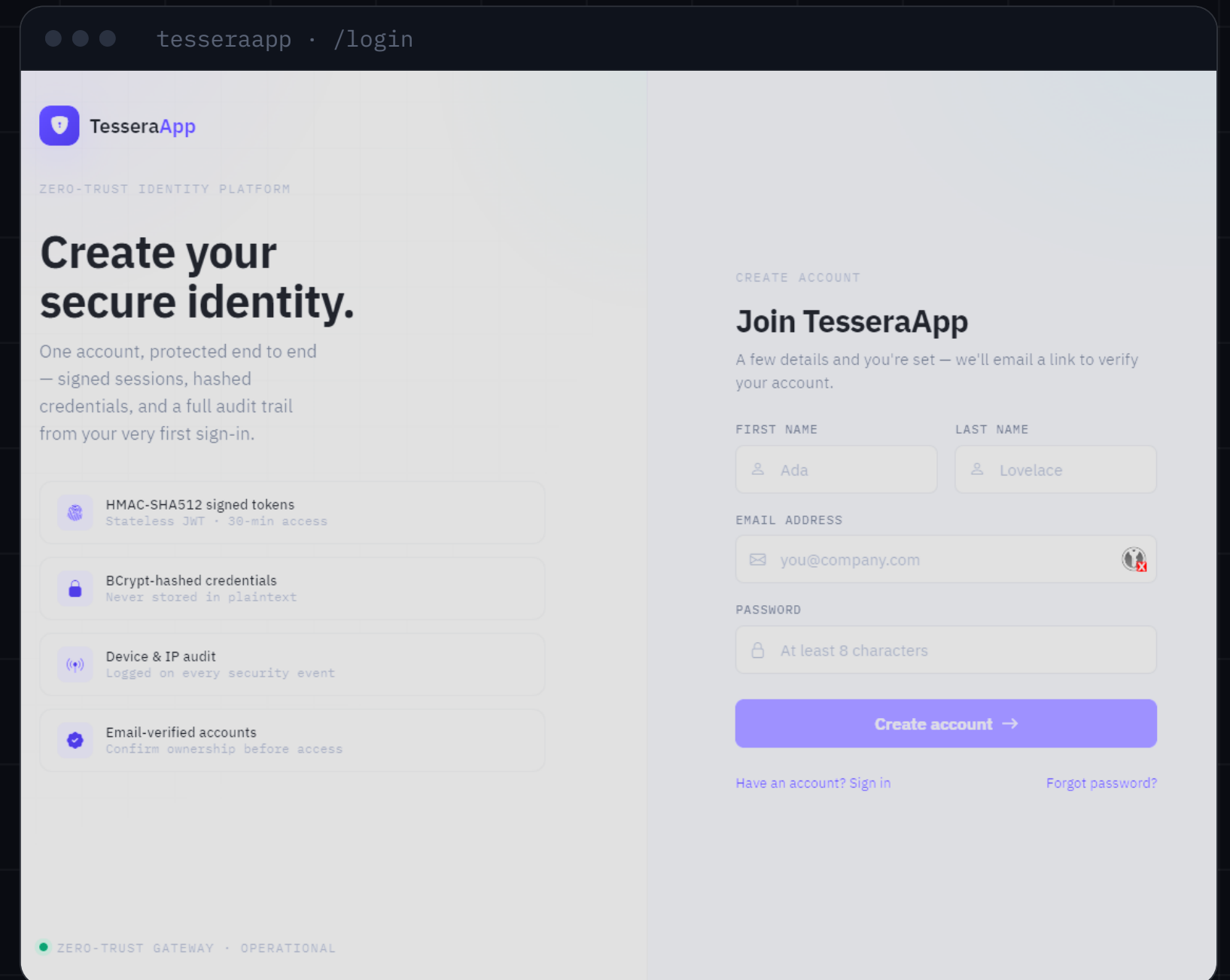
Click **Continue with GitHub** (Google / Microsoft configured as well)

Provider redirect → authorization-code exchange

Find-or-create the local user → our own JWT issued

Federated session appears in the **device list**; **link/unlink** from the profile

● WORKS LOCALLY AGAINST ALL THREE PROVIDERS



The screenshot shows the TesseraApp login interface. The browser address bar displays 'tesseraapp · /login'. The page features the TesseraApp logo and the tagline 'ZERO-TRUST IDENTITY PLATFORM'. The main heading is 'Create your secure identity.', followed by a description: 'One account, protected end to end — signed sessions, hashed credentials, and a full audit trail from your very first sign-in.' Below this, four security features are listed: 'HMAC-SHA512 signed tokens' (Stateless JWT · 30-min access), 'BCrypt-hashed credentials' (Never stored in plaintext), 'Device & IP audit' (Logged on every security event), and 'Email-verified accounts' (Confirm ownership before access). On the right, the 'CREATE ACCOUNT' section is titled 'Join TesseraApp' with the text 'A few details and you're set — we'll email a link to verify your account.' It includes input fields for 'FIRST NAME' (Ada) and 'LAST NAME' (Lovelace), an 'EMAIL ADDRESS' field (you@company.com), and a 'PASSWORD' field (At least 8 characters). A 'Create account →' button is at the bottom of this section, with links for 'Have an account? Sign in' and 'Forgot password?'. A status bar at the bottom left indicates 'ZERO-TRUST GATEWAY · OPERATIONAL'.

Staff-only surfaces — Admin & Insights

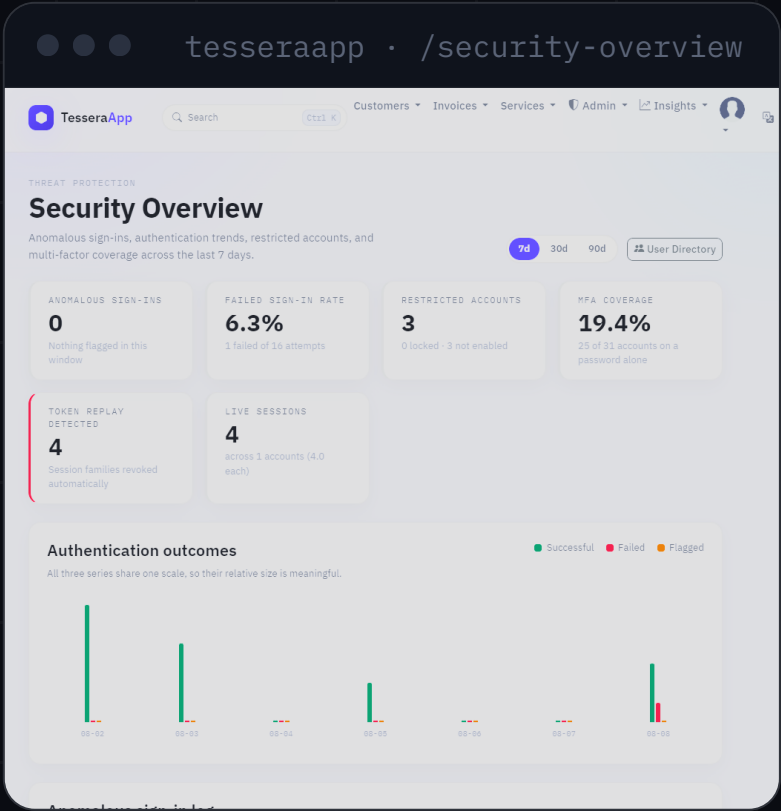
Open **Security Overview**: anomalies, lockouts, MFA coverage, token replay

Insights menu → **Analytics Hub** & **Billing Overview**

Manage Services: retire / reinstate catalog entries

Same URLs as **ROLE_USER** → menus gone, guard bounces, API 403s

ADMIN SESSION



The screenshot shows the 'Manage Services' page in the TesseraApp interface. The page title is 'Manage Services' under the 'ADMINISTRATION' section. It includes a sub-header 'Add, edit, and retire the offerings available on new invoices. Retired services stay here so they can be brought back — nothing is ever deleted.' and buttons for 'Public Catalog' and 'Add Service'. Below this is a table of services. The table has columns for 'SERVICES', 'DESCRIPTION', 'BASE PRICE', 'STATUS', and 'ACTIONS'. The services listed are: 'Identity & Access Review' (\$2,400.00, Offered), 'Single Sign-On Integration' (\$3,650.00, Offered), 'Multi-Factor Rollout' (\$1,800.00, Offered), 'Security Posture Assessment' (\$4,200.00, Offered), 'Cloud Migration' (\$7,500.00, Offered), 'Database Administration' (\$1,500.00, Offered), 'Web Application Development' (\$5,200.00, Offered), 'API Integration' (\$2,800.00, Offered), 'Compliance Reporting' (\$1,950.00, Offered), and 'Onboarding & Training' (\$950.00, Offered). Each service has 'Edit' and 'Retire' buttons in the 'ACTIONS' column. At the bottom, there is a pagination bar showing 'Rows per page: 10', 'Page 1 of 4', and '48 total'.

SERVICES	DESCRIPTION	BASE PRICE	STATUS	ACTIONS
Identity & Access Review	Audit of roles, permissions, and account lifecycle against least-privilege policy.	\$2,400.00	Offered	Edit Retire
Single Sign-On Integration	Connect an existing identity provider (Google, Microsoft Entra, Okta) via OAuth2/OIDC.	\$3,650.00	Offered	Edit Retire
Multi-Factor Rollout	Enrollment campaign and support onboarding for authentication-app MFA across an organisation.	\$1,800.00	Offered	Edit Retire
Security Posture Assessment	Review of authentication, session handling, and audit coverage with a prioritised findings report.	\$4,200.00	Offered	Edit Retire
Cloud Migration	Containerise and migrate an existing deployment to managed cloud infrastructure.	\$7,500.00	Offered	Edit Retire
Database Administration	Schema review, index tuning, backup verification, and restore rehearsal.	\$1,500.00	Offered	Edit Retire
Web Application Development	Custom feature development against the existing Angular and Spring Boot stack.	\$5,200.00	Offered	Edit Retire
API Integration	Design and build an integration between this platform and a third-party system.	\$2,800.00	Offered	Edit Retire
Compliance Reporting	Evidence pack assembled from the audit log for an external assessor.	\$1,950.00	Offered	Edit Retire
Onboarding & Training	Administrator and end-user training, delivered remotely with recorded sessions.	\$950.00	Offered	Edit Retire

RESULTS

Built to spec — and beyond it

7

RBAC ROLES ENFORCED

4

WAYS TO AUTHENTICATE

251

TESTS, CI-GATED

- ✓ Auth + MFA + RBAC + admin + business domain + audit — working end to end, **live on AWS**.
- ✓ TOTP MFA, refresh rotation with reuse detection, and **login-anomaly step-up** — SRS stretch goals that shipped.

CHALLENGES & LESSONS

What the build taught us

-  Migration-tool baseline drift → switched to an **idempotent schema script**.
-  ORM identifier-quoting pitfalls → **explicit column mappings**; identity domain kept on hand-written SQL.
-  Designing reuse detection to **commit-then-throw** — never roll back the revocation.

SHIPPED SINCE THE SRS — AND WHAT'S LEFT

Roadmap delivered, gaps named

✓ Shipped

Live on **AWS ECS Fargate** (ECR/ALB, Aiven MySQL); **164/87 tests gating in CI**; rate limiter + brute-force lockout; login-anomaly **step-up** + admin **security dashboard**; HTTPS via CloudFront; all three federated providers live with real credentials; **org-scoped customer/invoice reads**; database link fully **TLS-secured with certificate-identity verification** against a pinned CA.

⌚ Remaining work

End-to-end **Playwright** coverage of the security seams in the pipeline; **SMS 2FA** is Twilio-credentialed and code-complete but held on Twilio's A2P 10DLC campaign verification; **self-service organization management** — no UI yet to create an org or move a user between them.

CONCLUSION

A modern CIAM core, end to end

- ✓ A **complete, modern CIAM core** on a real application, validated against the SRS.
- ⚙ Hybrid stateless / stateful auth balances **scale and control** — zero-trust in practice.
- 🎯 Not "build beats buy" — but for the **underserved small-scale segment**, building in-house is defensible, and we showed it can be built correctly.



Thank you.

PRESENTERS

Robert C. Oliver, Jr. · Travis L. Lester

COURSE

CPSC 69100 · Lewis University

OPTIONAL • IF TIME ALLOWS

What we're most proud of

- ⚡ The **Angular development** side of this project — from framework basics to its **core and advanced features**.
- 📁 Ten standalone feature areas on **lazy-loaded routes**, with functional **guards** on every admin route.
- { } Advanced patterns in production: a capability-gating **structural directive**, a single-flight refresh **interceptor**, **signals**-driven state, runtime **i18n**.
- 🎓 Every one of the 103 carried-over components was reworked in Phase 2 — the framework knowledge compounded.